NIST CSF Risk Assessment & Remediation Report: Riverview Family Clinic

Client: Riverview Family Clinic

Prepared By: Patrick Kahindi Karisa

Date: March 23, 2026

Framework Version: NIST Cybersecurity Framework

1.Executive Summary

Riverview Family Clinic is a medium-sized healthcare provider managing Sensitive Patient Health Information (PHI) for approximately 5,000 patients. This audit was conducted to evaluate the clinic's security posture against the NIST Cybersecurity Framework.

Primary Finding: The clinic operates at an "Implementation Tier 1" (Reactive). The most significant risk is the Billing and Insurance Portal, which lacks granular access controls, creating a high probability of internal fraud or external data exfiltration. Following the recommendations in this report will transition the clinic to "Tier 3" (Repeated/Managed), significantly reducing the likelihood of a HIPAA violation.

---

2. Asset Inventory & Risk Register (Identify)

The following table represents the "Top 5" critical assets identified during the audit. Risk is calculated as Likelihood (1-3) * Impact (1-3).

Asset ID	Asset Name	Data Type	Primary Threat	Risk Score
AS 01	Billing/insurance Portal	Financial/PCI	Unauthorized Access	9(Critical)
AS 02	HER System	PHI	Ransomware/ Data loss	6(High)
AS 03	Front Desk Laptops	PII/PHI	Physical Threat/ Malware	6(High)
AS 04	Clinic Backup Drive	All	Logic Bomb/ Encrypt	6(High)
AS 05	Medical Imaging Server	Diagnostic	Hardware Failure/OS	4(Med)

---

3. Remediation & Control Strategy (Protect & Detect)

To mitigate the risks identified above, the following controls must be implemented within the next 90 days.

3.1 Access Control (Billing Portal)

- Current State: All administrative staff share a high-level login.
- Mitigation: Implement Role-Based Access Control (RBAC). Access will be restricted to the "Accounting" role only.
- Technical Control: Enable Multi-Factor Authentication (MFA) via authenticator app for all portal logins.
- Residual Risk: Reduced to 2.

3.2 Data Protection (EHR & Backups)

- Current State: Backups are stored on a local drive connected to the main network.
- Mitigation: Implement the 3-2-1 Backup Rule.
- Technical Control: Deploy an "Air-Gapped" or Immutable Cloud Backup solution (e.g., AWS S3 with Object Lock) to prevent ransomware from encrypting the backup files.
- Residual Risk: Reduced to 2.

3.3 Endpoint Security (Laptops)

- Current State: Laptops contain cached patient data and are not encrypted.
- Mitigation: Enforce Full Disk Encryption (FDE).
- Technical Control: Enable Windows BitLocker with recovery keys managed by a central administrator.
- Residual Risk: Reduced to 3.

---

4. Incident Response & Business Continuity (Respond & Recover)

Security is never 100%. This section outlines how the clinic will respond when a "Risk" becomes a "Reality."

4.1 Incident Response Plan (IRP)

In the event of a detected anomaly (e.g., unusual login spikes or encrypted files):

1. Detection: SIEM alerts or manual reporting.
2. Analysis: Determine if the breach involves PHI (HIPAA Trigger).
3. Containment: Isolate affected segments (VLANs) to prevent lateral movement.
4. Eradication: Remove malicious binaries and reset compromised credentials.

4.2 Business Continuity Plan (BCP)

- Recovery Time Objective (RTO): 4 Hours.
- Recovery Point Objective (RPO): 24 Hours (Daily Backups).
- Failover Procedure: If the EHR system is offline, the clinic will utilize "Emergency Paper Charts." Upon system restoration, data entry specialists will synchronize paper records back into the digital EHR.

---

5. Conclusion & Roadmap

The security of Riverview Family Clinic is currently hindered by technical debt and a lack of formal policy. By investing in MFA, Encryption, and Immutable Backups, the clinic protects its patients' privacy and avoids the catastrophic financial impact of a data breach.

Next Steps:

Month 1: Deploy MFA and BitLocker.

Month 2: Migrate backups to an immutable cloud provider.

Month 3: Conduct the first staff Security Awareness Training session.

Figure 1.1: Comprehensive Risk Assessment Matrix for Riverview Family Clinic. This table demonstrates the calculation of Inherent Risk (Likelihood * Impact) across all primary digital assets.

A	B	C	D
Asset Name	**Asset Category**	**Data Type**	**Criticality(1-10)**
EHR System	Software/Cloud	PHI (Protected Health Information)	10
Front Desk Laptops	Hardware	PII (Personally Identifiable Info)	7
Medical Imaging Server	Hardware/local	Diagnostic Data (X-rays, MRIs)	8
Billing and Insurance Portal	Software/Web	Financial/PCI Data	9
Clinic Backup Drive	Hardware/NAS	All Data Types	10

Figure 1.1 continuation

Why is it critical?	Threat	Vulnerability	Likelihood(1-3)	Impact(1-3)	Risk Score
If this is down, doctors can't see patient history or prescribe meds.	Ransmware	No Offline Backups	2	3	6
These are used for check-ins and payments. High risk for theft or malware.	Data Breach	No Disk Encryption	3	2	6
Stores large files locally. If corrupted, surgeries or diagnoses are delayed.	Hardware-Failure	End-Of-Life OS (win 7)	2	1	2
This is how the clinic gets paid. A breach here means financial fraud.	Unauthorized Access	No Principle Of Least Privileges	3	3	9
This is the "Safety Net." If this is compromised during a ransomware attack, the clinic is finished.	Logic Bomb	Default Passwords used	2	3	6

Figure 1.2: Remediation Strategy and Residual Risk Forecast. This artifact outlines the specific technical and administrative controls required to reduce the clinic's attack surface.

Asset Name	Current Risk Score	Security Control(The Fix)	Control Type
EHR System	6	Setup Immutable Cloud Backups (3-2-1 Rule) 3 copies, 2 different media, 1 offsite	Technical
Front Desk Laptops	6	Enable BitLocker Full Disk Encryption	Technical
Medical Imaging Server	4	Network Segmentation (VLAN)	Technical
Billing and Insurance Portal	9	Implement Role-Based Access Control (RBAC)	Technical
Clinic Backup Drive	6	Air-gapped Physical Storage	Physical

Figure 1.2 continuation

Residual Risk(Expected)
2
3
1
2
2